

Security risk assessment system for power monitoring systems based on zero trust architecture

Feng Wei*, Zhao Chen, Yin Wang, Dongqing Liu, Xun Zhang and Zhou Zhao

State Grid Gansu Electric Power Research Institute, Lanzhou, China

*Corresponding author's e-mail: weifeng2407@163.com

Abstract—With the continuous expansion of cyberspace, power systems face increasingly severe challenges from external hacker attacks and internal risks. Traditional security models based on perimeter defense can no longer meet the high-security requirements of modern power monitoring systems. This paper proposes a security risk assessment system for power monitoring systems based on the zero trust security model, aiming to address the challenges of external hacker attacks and internal risks faced by power systems. The system collects and analyzes various data in real time, using modular processing and a comprehensive scoring mechanism, and dynamically generates security status levels. On this basis, it implements security policies. Experimental results show that the system can effectively identify and respond to security threats, significantly reducing false alarms or missed alarms caused by single data sources and providing an efficient and reliable security solution for the power monitoring field.

Keywords—Security of Power Monitoring Systems, Zero Trust Model, Dynamic Risk Assessment, Trust Level and Risk Rating

I. INTRODUCTION

Against the backdrop of the deep integration of information and network technologies, power systems have become critical national infrastructure. Their safe and stable operation is essential for national security and social stability. However, power systems also face severe cybersecurity threats [1]. According to the "Global Energy Internet Development Report," more than 100 major cybersecurity incidents were recorded in the global power industry in 2020, with national-level Advanced Persistent Threat (APT) organizations involved in several of these incidents. The 2019 cyberattack on Venezuela [2] highlighted the vulnerability of power monitoring systems and their impact on socio-economic operations.

Currently, the security of power monitoring systems faces two main challenges: external hacker attacks and internal risks [3]. Despite the presence of multi-layered defense measures such as firewalls, Intrusion Detection Systems (IDS), and Security Information and Event Management (SIEM) systems, these defenses often fall short against complex network threats [4]. The periodic nature of security risk assessments and the lag in emergency response further limit the effectiveness of protective measures.

To address these challenges, this paper proposes a real-time risk assessment system based on the zero-trust security model. The system collects and analyzes data from the power system in real time, employs a modular processing approach, generates system security status levels, and executes corresponding security policies, thereby providing dynamic and precise protection for power systems.

II. ZERO TRUST SECURITY MODEL

The Zero Trust security architecture [5, 6], as a forward-looking security strategy, requires all access requests to undergo strict verification, regardless of their source. The Zero Trust security model is based on a core architectural principle, which is to build a security ecosystem centered around identity authentication and situational awareness [7]. In this model, the approval of any access request is strictly contingent upon the authenticity of the user's identity and the contextual environment of the request.

The technical implementation of the Zero Trust security model includes several aspects: using multi-factor authentication [8, 9] to improve identity verification accuracy, implementing policy-driven access control to refine permission management [10], and deploying micro-segmentation technology to reduce the potential attack surface. In power monitoring systems, the Zero Trust model establishes robust security defenses by granting access only to thoroughly verified individuals, reducing internal security risks and defending against external attacks. Combined with continuous monitoring and automated emergency responses, the system can quickly address security threats, ensuring the stability and reliability of power monitoring systems.

III. SYSTEM DESIGN

A. System architecture

The core verification process of the Zero Trust model includes the following key dimensions: identity authentication, device health status assessment, fine-grained access control, data encryption, and logical isolation. This model also emphasizes continuous real-time monitoring and analysis, dynamic verification, and a comprehensive audit reporting system. The system design focuses on the three main functions of the Zero Trust model: real-time monitoring and analysis, comprehensive risk assessment, and detailed audit tracking and reporting. The system structure is shown in Figure 1.

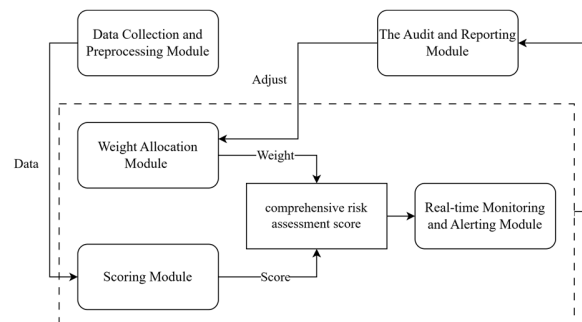


Figure 1. Real-time risk assessment system for power system security.

The system operation process can be described as follows. First, the data collection and preprocessing module collects the required data from relevant devices in the power system according to preset parameters and preprocesses it, converting the data into a standardized format that the various submodules of the scoring module can directly process. Next, the scoring module and the weight allocation module collaborate to calculate the processed data based on the preset risk assessment model, obtaining the system's current comprehensive risk assessment score. During this process, the scoring module also incorporates historical scoring data. It applies user behavior similarity detection to determine whether any abnormal behaviors are present, incorporating this result into the comprehensive risk assessment score.

Subsequently, the real-time monitoring and alerting module maps the security score to a preset trust level and implements corresponding security strategies based on the mapping results, such as restricting access, increasing the monitoring level, or triggering stricter protection measures. Additionally, the real-time monitoring module has dynamic adjustment capabilities to respond to the constantly changing risk environment, ensuring that the system remains in an optimal protective state under different conditions. The audit and reporting module periodically records the entire scoring process, generating logs that allow system administrators to adjust the weight parameters of the weight allocation module based on the logs, and ensuring

that the system can continuously respond to emerging threats and maintain efficient security management.

B. Weight configuration

The initial values of the weight factors are set based on expert experience, covering various data sources such as user behavior, device status, and network traffic. Each weight factor represents the contribution of the corresponding scoring submodule to the overall risk score. For example, abnormal behavior of certain critical devices may have a greater impact on system security, and therefore, the weight of the relevant scoring module should be appropriately increased. The system adopts a dynamic weight adjustment mechanism, which periodically evaluates and updates the weight distribution strategy based on historical data recorded by the audit and reporting module. By analyzing the frequency and severity of security incidents, the weight factors can reflect changes in different threats within the system, enabling flexible responses during system operation. After each audit report, system administrators can manually adjust the weight parameters according to audit recommendations or allow the system to automatically adjust them based on preset rules.

C. Risk assessment

The system uses a user set $Users = \{U_1, U_2, U_3, \dots, U_n\}$ to identify each user, where U_i is defined as a 4-tuple: $\{ID_i, RLS_i, ORLS_i, TL_i \mid i = 1, 2, \dots, n\}$. The specific details are described in Table 1.

Table 1. Attributes of user set components.

Attributes	Description	Data Format	Value Range
ID	User identity identifier	Numeric or String	
RLS	User Risk Level Score	n-dimensional vector, where n is the number of scoring submodules	0.0~10.0
ORLS	User Overall Risk Level Score	Numeric	0.0~10.0
TL	User Trust Level	String	Trusted, Moderate Risk, High Risk, Untrusted

D. Trust level classification

1) *Similarity*. In the user set $Users$, each user has an RLS vector representing their score on various risk items. Since the permissions requested by users during daily work change minimally, their RLS vectors generally remain relatively stable. Based on this, when a user's RLS vector is updated, the system uses the real-time monitoring module to retrieve historical RLS vectors and calculate the similarity to assess the user's state. Similarity is measured using cosine similarity, where a result closer to 1 indicates higher similarity. To reduce computational costs and ensure real-time response, the system employs a KD-tree combined with vector similarity for evaluation, with the specific steps as follows:

- 1) The KD-tree is initialized, and the user's historical RLS vectors are stored as nodes.
- 2) When the user's RLS vector is updated, we use the KD-

tree to quickly locate nodes close to the new vector and calculate the similarity.

- 3) If the real-time monitoring module detects an anomaly, the user's trust level is lowered, an alert is sent, and the action is logged, while the vector is deleted from the user's historical records.

2) *Trust level*. In the power monitoring system, the timeliness of access control is critical. The system must quickly identify insecure access or risky users and take immediate action to minimize potential losses. Therefore, this system adopts a four-level security policy to ensure rapid response, avoiding delays caused by overly complex policies that could impact the system's real-time performance. The system matches users to appropriate security policies based on their trust level, which is divided into four levels. Detailed information can be found in Table 2.

Table 2. Trust levels and security policies.

Trust Level	Trust Degree	Security Policies
Trusted	8.0~10.0	Provide access to higher-level services Reduce the frequency of security checks Offer fast lanes or priority support
Moderate Risk	5.0~8.0	Remind users to pay attention to security settings and behaviors Increase the frequency of security checks Limit certain sensitive operations until the risk is mitigated
High Risk	2.0~5.0	Enforce security measures, such as password changes Limit or suspend certain functions until the risk is resolved Conduct in-depth security reviews and monitoring
Untrusted	0.0~2.0	Completely restrict or prohibit access to the system Conduct thorough security reviews

IV. EXPERIMENTAL AND ANALYSIS

A. Experimental environment

The experimental platform is equipped with an Intel Core i7-9750H processor, 32GB DDR4 memory, and an NVIDIA GeForce GTX 1660 Ti GPU. Python is used to build the experimental simulation platform for analyzing and validating the system solution. The experiment uses the NSL-KDD dataset and log files extracted from real servers. By combining these two data sources randomly, the merged dataset includes predefined normal and abnormal behavior patterns from NSL-KDD and dynamic changes reflected in the log files from real network environments.

B. Experiment on the scoring module

This experiment validated the risk identification capability of the new system in power monitoring. We used 1,127 sets of simulated data, combining login logs and network traffic records

for scoring and categorizing into four trust levels: "Untrusted," "High Risk," "Moderate Risk," and "Trusted." Based on the data from Figures 2(a) and 2(b), the login log module tended to be extreme, marking most files as "Untrusted," which made the classification inflexible and potentially misclassified low-risk files. The network traffic module struggled to distinguish between normal and malicious access, leading to most access being labeled as risky. In contrast, as shown in Figure 2(c), the comprehensive scoring module is more balanced, enabling detailed risk assessment, ensuring that high-risk files are prioritized while reducing misclassification and minimizing disruptions to normal operations. Overall, the system accurately differentiates between various risk levels, and if more scoring modules are added in the future, the accuracy of the system's risk assessment will further improve.

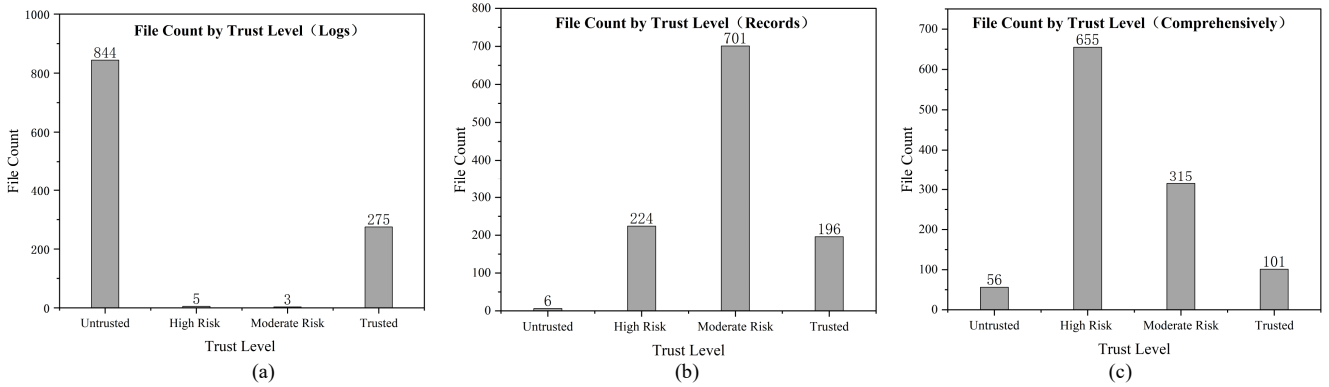


Figure 2. (a) Log module scoring results, (b) network traffic records module scoring results, (c) comprehensive scoring results.

C. Similarity calculation experiment

This experiment compared the performance of the KD-tree method and the traditional method in terms of similarity computation time and accuracy, evaluating the advantages of the KD-tree. A set of 1,000 RLS score vectors was generated, with

a similarity threshold of 0.95 and the number of nearest neighbors set to 50. Through 500 tests, the KD-tree method only compared nearby nodes, which could lead to misclassification. If the KD-tree's result differed from the traditional method, it was considered an error. The detailed results are shown in Figures 3(a) and 3(b).

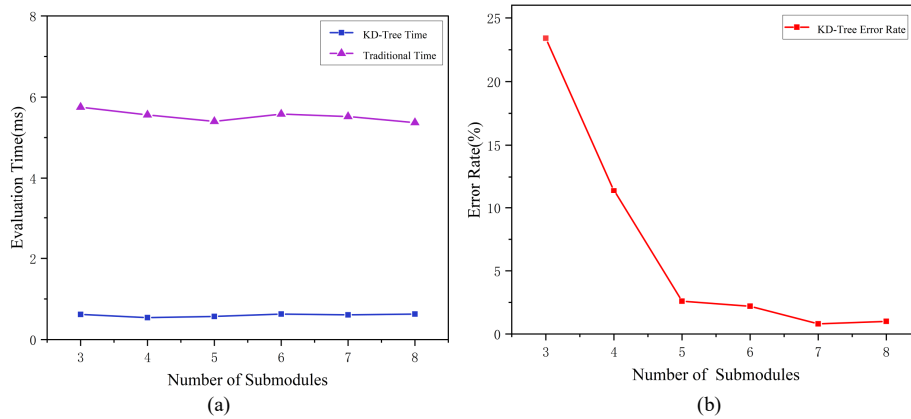


Figure 3. (a) The impact of the number of submodules on evaluation time, (b) the impact of the number of submodules on KD-tree error rate.

The results showed that the KD-tree method was, on average, about 5 milliseconds faster than the traditional method in similarity computations, and this advantage persisted as the number of submodules increased. Although there was a significant error when the number of submodules was small, as the number of submodules increased, the accuracy of the KD-tree method improved and stabilized, with a significant reduction in error rate. This indicates that the KD-tree effectively enhances computation speed when handling a large number of submodules, meeting the system's real-time performance requirements.

V. CONCLUSION

The system, with its core functions of real-time monitoring, risk assessment, and audit tracking, has established a comprehensive risk assessment system for power monitoring. Experiments validated its accuracy in detecting abnormal access and assessing risk, demonstrating the system's ability to timely identify security threats and reduce false positives and false negatives. This indicates that the system is effective and reliable in practical applications, providing a viable security solution for the power monitoring field.

REFERENCE

- [1] Z. Liang, L. Kong, and H. Pan. Challenges and Key Technologies for New Power Systems [J]. Power and Energy, 2024, 45(02):154-159.
- [2] C. Tang. Analysis of Network Security Monitoring System Construction for Power Monitoring Systems [J]. Mechatronics and Information, 2020, (32):142-143.
- [3] J. Guo. Discussion on Security Protection of Wind Power Plant Power Monitoring System [J]. Electrical Technology and Economics, 2023, (07):300-302.
- [4] Q. Du, H. Xu, X. Zheng, et al. Design of Defense Strategy for Power Monitoring System against Malicious Network Attacks [J]. Control Engineering, 2024, 31(01):185-192.
- [5] M. Shore, S. Zeadally, and A. Keshariya, "Zero Trust: The What, How, Why, and When," in Computer, vol. 54, no. 11, pp. 26-35, Nov. 2021, doi: 10.1109/MC.2021.3090018.
- [6] B. Guo, J. Wang, L. Ma, et al. Research on Dynamic Access Control Model for Sensitive Data Based on Zero Trust [J]. Information Network Security, 2022, 22(06): 86-93.
- [7] J. Yao, L. Kong, and Y. Guan. Discussion on Key Security Technologies for Industrial Control Systems Based on "Zero Trust" [J]. Industrial Information Security, 2023(06): 17-22.

- [8] X. Liu, J. Wang, M. Wang, and R. Zhang, "Improved LTE-R Access Authentication Scheme Based on Blockchain and Secgear," in IEEE Internet of Things Journal, vol. 11, no. 6, pp. 10537-10550, 15 March 15, 2024.
- [9] X. Liu, Z. Guo, J. Ma, and Y. Song, "A Secure Authentication Scheme for Wireless Sensor Networks Based on DAC and Intel SGX," in IEEE Internet of Things Journal, vol. 9, no. 5, pp. 3533-3547, 1 March 1, 2022.
- [10] L. Zhang, D. Chen. Research on Dynamic Access Control Model Based on Zero Trust [J]. Information Security Research, 2022, 8(10):1008-1017.